

Sentinel

auto-ban for password-guessing bots

Result week: bots hammer the college portal guessing passwords.
Nobody notices until students can't log in.

What Sentinel does

Reads login logs, bans an IP after **10 failures in 60 s**, never touches real students, and lifts the ban **at the exact millisecond** it expires.

Built from

A clean-room rebuild of the core of **CrowdSec**, written only from our own docs. Node.js, Express 5, built-in SQLite.

REVERSE IT

What CrowdSec really does (and where it falls short)

FINDING (VERIFIED FILE:LINE)	WHY IT MATTERS FOR OUR CARD
Leaky bucket overflows on capacity + 1 <code>leakybucket/README.md:24-26, bucket.go:263</code>	It is a rate limit, not "10 in a minute". A slow bot under the leak rate is never caught .
Blocking is done by a separate bouncer that polls <code>apiserver/controllers/controller.go:148</code>	Bans start and end late , up to one polling interval.
Escalating bans exist but are commented out <code>config/profiles.yaml:8</code>	The same bot returns every 4 h.
Brute-force rules are not in the repo (Hub download); there is no web UI <code>config/detect.yaml:408</code>	Hard for a college IT cell to run.

One process: detect and enforce, with no delay



Exact rule

The **10th** failure inside any 60-second window bans.
The count comes from stored timestamps, so a restart never loses or invents failures.

Exact expiry

A ban is active only while `now < until`, checked on **every request** by the ban gate. No cleanup job, no polling.

KILLER TESTS

All 3 pass:

29 / 29 tests green

KILLER TEST	HOW WE PROVE IT (NPM TEST)
1. 10 failed logins from one IP in a minute → banned	9 failures → no ban · 10th → 403 · failures spread over 63 s → no ban · 10 sshd or nginx log lines → ban · 20 parallel requests → exactly 1 ban
2. A normal user at the same time is not affected	Student logs in 200 before, during and after the attack · 3 typos ≠ ban · allowlisted IP never banned
3. Ban lifted exactly when it expires	At until - 1 ms → 403 · at until → 200 · one failure after expiry does not re-ban

Better than the original for a college IT cell

1 · Escalating bans

The nth ban lasts $n \times$ the base duration, capped. A student who mistypes gets 60 s; a returning bot gets 2 min, 3 min, and so on. CrowdSec ships this switched off.

2 · Live admin dashboard

Active bans with live countdowns, one-click unban, an allowlist for shared college IPs, and the top attacking IPs. CrowdSec has no web UI in its repo.

Live demo: a bot sends 10 wrong passwords → **banned on the 10th** · a student keeps logging in → **never blocked** · the countdown hits 0 → **ban lifted**.